black hat®
EUROPE 2025

DECEMBER 8-11, 2025

EXCEL LONDON / UNITED KINGDOM

black hat EUROPE 2025

AI VS. AI

Building Resilient Enterprises in the Age of Autonomous Threats

DINIS CRUZ

GenAI Entrepreneur & Former CISO Akeia.ai / The Cyber Boardroom / MyFeeds.ai

THE PERFECT STORM

Why This Moment Is Different

SECURITY'S FOUR PILLARS - ALL BROKEN

ENGINEERING & TECHNOLOGY

We know how to build secure systems - we don't do it at scale

BUSINESS PROCESSES

Security is an afterthought, not embedded in decisions

FUNDING & FOCUS

NFRs chronically underfunded - features always win

RISK MANAGEMENT

Spreadsheets and heat maps disconnected from technical reality

Systems are insecure not because engineers are stupid, but because the ENVIRONMENT forces corner-cutting. All four pillars must be aligned.

WE'VE BEEN GETTING AWAY WITH IT

AWS

Timing bug wiped out a global database

AZURE

Config inconsistency silently propagated, then 'detonated' worldwide

CLOUDFLARE

Routine config change crashed bot defense, halted traffic

CROWDSTRIKE

8.5 million Windows systems bricked by a faulty update

These weren't sophisticated attacks - they were minor glitches that cascaded. Now imagine if they were deliberate, coordinated attacks.

THE NEW INSIDERS

Autonomous Agents as Threat Actors

THREE CATEGORIES OF AI-DRIVEN THREATS

MALICIOUS AI AGENTS

Fully autonomous malware that learns, adapts, and persists

COMPROMISED BENIGN AGENTS

Your AI bots hijacked via prompt injection - operating with legitimate access, now working for the adversary

UNINTENTIONALLY HARMFUL AGENTS

The paperclip maximizer scenario - dangerously efficient in ways we didn't anticipate

Prompt injection remains unsolved - any AI taking untrusted input can be subverted.

HUMAN INSIDERS VS. AI AGENTS

VS

HUMAN INSIDERS	AI AGENTS
Natural limitations on skill and time	Tireless, infinite patience
Rarely had maximal destructive intent	Machine-speed adaptation and iteration
Fatigue, fear of detection, single-threaded	Finds alternate paths when blocked
Contained failures - couldn't scale chaos	No moral compass unless explicitly constrained

We've never had a malicious insider that can instantly devise new approaches when initial attempts fail. AI doesn't give up - it gets creative.

WHY ENTERPRISES AREN'T READY

Fragile by Design

FRAGILE BY DEFAULT

TECHNICAL DEBT CRISIS

- ~40% of IT asset value is technical debt (McKinsey)
- Systems running 'hot' with minimal safety margins

HIDDEN INTERDEPENDENCIES

- Internet = circular dependency machine
- Identity, DNS, cloud, CDN - one failure cascades globally

NO VISIBILITY, NO RECOVERY

- Only ~54% have documented DR plans - fewer actually test them
- Average breach detection: 9 months of dwell time

NO VERSION CONTROL FOR DATA

- Code has Git. Databases? Configs? Often nothing.
- If an AI corrupts records, can you rewind?

You can't protect what you don't understand. You can't recover what you haven't practiced.

THE DEFENDER'S EDGE

AI as Force Multiplier, Not Black Box

ATTACKERS ALWAYS MAKE MISTAKES

THE '100% PREVENTION' MYTH

- You cannot patch everything, eliminate every gap
- And you don't have to

EVERY ATTACK HAS 5-10 MISSTEPS

- Unusual logins, wrong processes, odd data movement
- Attackers lack perfect insider knowledge - they wander, they probe

YOUR JOB: CATCH THE MISTAKES

- Before they reach the crown jewels
- Whether it's an external attacker OR your own AI spiraling

Perfect prevention is impossible AND unnecessary. Detection and response are the asymmetric advantage.

SECURITY'S ASYMMETRIC ADVANTAGE

UNIQUE ENTERPRISE-WIDE VANTAGE POINT

- Access to every system, every data flow
- One of few functions focused on business SURVIVAL, not narrow objectives

YOU KNOW WHAT 'GOOD' LOOKS LIKE

- You define the baseline - attackers must deviate from it
- The moment something acts outside normal, you catch it

HOME COURT ADVANTAGE

- Attackers wander chasing dead ends, making noise
- You know the terrain - use it

Defenders think in lists, attackers think in graphs. We need to arm defenders with graphs - and the AI to make sense of them.

THE MECHANISM: KNOWLEDGE GRAPHS

BUILD A DIGITAL TWIN OF YOUR ENTERPRISE

- Systems, data flows, identities, dependencies - all connected
- Not static docs - a living, queryable model

SEMANTIC GRAPHS LINK EVERYTHING

- Each team's data model connects to the whole
- Query: 'What breaks if System X goes down?' - instant answer

AI BUILDS AND MAINTAINS THE GRAPH

- LLMs digest docs, configs, logs into structure
- Humans make decisions, AI updates the map continuously

Use GenAI to BUILD the knowledge, but deterministic systems for real-time enforcement. The graph is your situational awareness.

black hat EUROPE 2025

RADICAL SIMPLIFICATION

The Answer Isn't More Complexity

ASSUME COMPROMISE, CONTAIN BLAST RADIUS

STRONG SEGMENTATION INSIDE

- Crown-jewel systems walled off with strict controls
- One-way isolation for legacy components that can't be fixed

GRACEFUL DEGRADATION = VICTORY

- Parts may fail, but they fail SAFELY
- No cascade into total enterprise collapse

HARDENED BOUNDARIES AROUND WHAT CAN'T BE FIXED

- API throttles for fragile older systems
- Circuit breakers that halt abnormal transactions automatically

Every agent you add to mission-critical systems becomes part of your attack surface. Simplify first.

VERSION CONTROL EVERYTHING

CODE HAS GIT. WHAT ABOUT DATA?

- If an AI corrupts your database, can you rewind?
- Most orgs: No version history, no audit trail, no rollback

IMMUTABLE LOGS, APPEND-ONLY WHERE POSSIBLE

- Every change recorded and reversible
- Tampering becomes evident because history can't be rewritten

CONSIDER FILE SYSTEM AS DATABASE

- Simpler architecture = smaller attack surface
- Standard backup/versioning tools work out of the box

SBOMs act like Git commits for software. Extend that concept to ALL enterprise data.

IDENTITY GRAPHS: LEAST PRIVILEGE AT SCALE

MAP EVERY IDENTITY AND PERMISSION

- Users, services, AI agents - all in one graph
- Query: 'If this account is compromised, what can it reach?'

JUST-IN-TIME, JUST-ENOUGH ACCESS

- Privileges that EXPIRE, not persist
- Admin rights only when explicitly unlocked, auto-revoke after

SHRINK THE BLAST RADIUS

- One compromised account ≠ full breach
- Attacker hits walls immediately - can't pivot everywhere

Identity is the new perimeter. Zero Trust isn't a product - it's this architecture.

FUND NFRS AT UNPRECEDENTED SCALE

TEST YOUR RECOVERY - FOR REAL

- Backup drills that actually restore, not just 'assume it works'
- Chaos engineering beyond normal peaks - AI hammers APIs 24/7

INSTRUMENT EVERYTHING

- Real-time visibility into what's happening across systems
- If it isn't measured, it doesn't get managed - or funded

SIMPLIFY RUTHLESSLY

- Consolidate workflows - 7 microservices → 3 on one platform
- Pause new AI deployments until the foundation can support them

DEMAND VENDOR ACCOUNTABILITY

- The market doesn't currently punish fragility - change that in contracts
- Require SBOMs, security labels, evidence of secure development

ENABLING INNOVATION

Security as Enabler, Not Gatekeeper

VIBE CODING: THE NEW SPREADSHEETS

CREATING SOFTWARE IS NOW TRIVIALLY EASY

- Non-engineers building apps via AI prompts
- If the software doesn't exist, they will it into existence over coffee

SAME PATTERN AS EXCEL - ON STEROIDS

- Solves immediate problem brilliantly
- Becomes mission-critical overnight with zero governance

SHADOW AI IS ALREADY HERE

- Employees pasting sensitive data into ChatGPT daily
- Department-level AI tools running under IT's radar

Just like spreadsheets couldn't be banned, vibe coding won't be stopped. The question isn't IF but HOW you govern it.

DON'T BECOME THE DEPARTMENT OF 'NO'

THE HORSE HAS BOLTED

- Employees will use AI regardless of policy
- Shadow-IT AI is far worse than governed AI

SECURITY AS ENABLER AND GUIDE

- Provide vetted platforms and clear guidelines
- Build safe internal AI services before they run to ChatGPT

CREATE HANDOFF PATHWAYS

- Pair business 'vibe coders' with engineering buddies
- When a prototype gets traction, help industrialize it safely

We did this for cloud - shifted from 'no cloud' to 'here's a secure cloud framework'. Time to do it again for GenAI.

black hat EUROPE 2025

THE PATH FORWARD

From Reactive Firefighting to Proactive Containment

CALL TO ACTION

BUILD YOUR DIGITAL TWIN NOW

- Knowledge graphs of your enterprise - don't wait for a crisis

INVEST IN DETECTION OVER PREVENTION

- Catch the 5-10 mistakes attackers will make

SIMPLIFY RUTHLESSLY

- Every agent you add is attack surface - earn its place

VERSION CONTROL EVERYTHING

- Data, configs, permissions - if you can't rewind, you can't recover

ENABLE, DON'T BLOCK

- Govern vibe coding before it governs you

The side that UNDERSTANDS faster wins. Not the side that deploys more AI.

QUESTIONS?

@DinisCruz | The Cyber Boardroom | Akeia.ai